Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Asset Management	The data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to business objectives and the organization's risk strategy.	Physical devices and systems within the organization are inventoried.	1. Do you an up to date CMDB or asset inventory of all physical (hardware) device? 2. How you perform periodic review on the CMDB to ensure that it's accurate and up to date?	Pass	CMDB Needs periodic reviews.
		Software platforms and applications within the organization are inventoried.	1. Do you an up to date CMDB or asset inventory of all software assets such as critical applications? 2. How you perform periodic review on the CMDB to ensure that it's accurate and up to date?	Fail	SaaS applications should be added to CMDB, they should be classified as per sensitivity and criticality.
		Organizational communication and data flows are mapped.	1.Do you have clear, up to date, network diagrams - including the cloud environment?	Pass	
		External information systems are catalogued.	1. Does your CMDB include Software-as-a-Service (SaaS) instance catalogued and classified as per sensitivity and criticality? 2. Do you have an up to date inventory of all third party suppliers?	Fail	Software and suppliers aren't included in the CMDB
		Resources (e.g., hardware, devices, data and software) are prioritized based on their classification, criticality and business value.	1. Are assets in the CMDB classified based on sensitivity and criticality?	Fail	
		Cybersecurity roles and responsibilities for the entire workforce and third-party stakeholders (e.g., suppliers, customers, partners) are established.	1. Are cyber security roles and responsibilities defined? 2. Is there a clear information security policy outlining roles and responsibilities for cyber security (including third part suppliers) ?	Fail	
Business Environment	The organization's mission, objectives, stakeholders, and activities are understood and prioritized; this information is used to inform cybersecurity roles, responsibilities, and risk management decisions.	The organization's role in the supply chain is identified and communicated.	1. Does the organisation have clear documentation outlining their role within their own supply chain when it comes to cyber security? This is accomplished by having a clear mapping of third party suppliers, classifying suppliers based on criticality and sensitivity.	Fail	Oscorp does not have a process to manage cyber security supplier risk
		The organization's place in critical infrastructure and its industry sector is identified and communicated.	1. Is this organisation considered 'critical infrastructure' ? Examples of this will include intelligence agencies, national communication organisations, transportation, etc. These are organisations that are part of 'national security'. If the answer is YES, then this needs to be documented in the information security policy and communicated clearly to senior stakeholders.	N/A	Oscorp is not a critical infrastructure organisation
		Priorities for organizational mission, objectives and activities are established and communicated.	The organisation has a clear business strategy and mission statement.	Pass	
		Dependencies and critical functions for delivery of critical services are established.	1. Does the organisation have key critical services and applications inventories and classified? 2. Does the organisation have business continuity plans and disaster recovery plans for key critical services?	Fail	Assets and supplies should be classified based on critical and sensitivity. The organisation should have a clear list of their key critical assets at minimum
		Resilience requirements to support delivery of critical services are established.	1. Determine if the organization's business continuity and disaster recovery plans (including business impact analysis) support resilience of critical services. 2. Determine if appropriate due diligence (e.g., business continuity plans (BCP), service level agreements (SLA), Service Organization Control (SOC) reports) information is in place and reviewed to ensure resilience requirements of the organization can be met by critical third-party services.	Pass	
Governance	The policies, procedures, and processes to manage and monitor the organization's regulatory	Organizational information security policy is established.	1. Does the organisation have an information security policy?	Fail	
		Information security roles and responsibilities are coordinated and aligned with internal roles and external partners.	1. Have information security roles and responsibility been documented and communicated with internal and external stakeholders (i.e. third party suppliers) ?	Fail	

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Governan	organization's regulatory, legal, risk, environmental, and operational requirements are understood and inform the management of cybersecurity risk.	Legal and regulatory requirements regarding cybersecurity, including privacy and civil liberties obligations, are understood and managed.	1. The organisation's legal and regulatory responsibilities from an information security point of view is well documented. This includes complying with privacy laws and other cyber security regulations.	Fail	
		Governance and risk management processes address cybersecurity risk.	1. The organisation has a mature and established processes and procedures to manage cyber security risks. 2. The board of directors have oversight of information security issues (governance)	Fail	Cyber security risk are not documented. Therefore, the board has no visibility over cyber security risks.
Risk Assessment	The organization understands the cybersecurity risk to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals.	Asset vulnerabilities are identified and documented.	1. Vulnerability scans are conducted and vulnerabilities are analysed and documented.	Fail	Current vulnerability scans are ad-hoc. Coverage is not clear.
		Threat and vulnerability information is received from information sharing forums and sources.	1. vulnerability management program includes subscriptions to various threat intelligence sources to get information about the latest threats and vulnerabilities.	Fail	There is no cyber security team or a cyber security function to do this activity.
		Threats, both internal and external, are identified and documented.	1. Cyber security threats assessments have been conducted 2. thread actors have been identified, assessed, and documented	Fail	
		Potential business impacts and likelihoods are identified.	1. Cyber security risk assessments include business impact and likelihood as a critical step to determine the level of risk	Fail	
		Threats, vulnerabilities, likelihoods and impacts are used to determine risk.	1. Determine if the risk assessment process identifies reasonably foreseeable internal and external threats and vulnerabilities, the likelihood and potential damage of those threats, and the sufficiency of controls to mitigate the risk associated with those threats.	Fail	
		Risk responses are identified and prioritized.	1. Are recommendations/outcomes of the risk assessment process prioritised based on criticality and impact to the business?	Fail	
Risk Management Strategy	The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support operational risk decisions.	Risk management processes are established, managed and agreed to by organizational stakeholders.	1. Has the risk management process been endorsed by senior management?	Fail	
		Organizational risk tolerance is determined and clearly expressed.	1. Determine if the organization has defined and approved a cyber risk appetite statement. This will be derived from the risk tolerance of the organisation.	Fail	
		The organization's determination of risk tolerance is informed by its role in critical infrastructure and sector-specific risk analysis.	1. If the organisation is considered a critical infrastructure, then the cyber risk and overall risk tolerance should take this into consideration.	N/A	Oscorp is not a critical infrastructure organisation

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Access Control	Access to assets and associated facilities is limited to authorized users, processes, or devices, and to authorized activities and transactions.	Identities and credentials are managed for authorized devices and users.	Describe all aspects of identity and access management, including: 1. Describe the process used to manage username, passwords, identities. 2. Describe your password policy 3. Do you use multi-factor authentication? 4. Do you have a process to off-board users who left the organisation? 5. Do you conduct regular user access reviews?	Fail	While active directory is in use. There aren't enough controls in place to manage authorisation effectively. i.e. no two factor authentication, no approval process for requesting access to resources, shared admin password. Further improvements required
		Physical access to assets is managed and protected.	Describe your physical security process: 1. do you use CCTV? 2. Do you log who gets access to rooms? There is a key card to swap? 3. Do you make use of biometrics?	Pass	
		Remote access is managed.	1. Do you VPN for remote access? 2. Is two-factor authentication required for VPN connections? 3. How do contractors and third-party providers access your environment?	Fail	VPN is in use, but two factor authentication isn't in place. Contractors remote access isn't managed. Further improvements required
		Access permissions are managed, incorporating the principles of least privilege and separation of duties.	1. Are the principle of least privilege and separation of duties followed across the organisation? 2. Do you conduct regular reviews to validate that the principle of least privilege and separation of duties are followed consistently across the organisation?	Fail	
		Network integrity is protected, incorporating network segregation where appropriate.	1. Ask the network team if they segment the network and how they do it.	Pass	
Awareness Training	The organization's personnel and partners are provided cybersecurity awareness education and are adequately trained to perform their information security-related duties and responsibilities consistent with related policies, procedures, and agreements.	All users are informed and trained.	1. Do you conduct regular security awareness training? 2. Is the training mandatory for all employees who join the organisation? 3. Do you enforce the training on contractors?	Pass	Pass, but the process could be improved: Employees should undergo security training at least once every 12 months. Consider running simulated phishing attacks to further improve awareness.
		Privileged users understand roles and responsibilities.	1. Do you have a process to manage privileged users / privileged accounts? 2. Do you use a tool to manage privileged access? Is it operational?	Fail	There is process to manage privileged user accounts. Admin passwords are shared.
		Third-party stakeholders (e.g., suppliers, customers, partners) understand roles and responsibilities.	1. Does your contract with third-party suppliers include clauses to ensure information security standards are met? 2. Do conduct cyber security assessments on third party suppliers before onboarding them?	Fail	
		Senior executives understand roles and responsibilities.	1. Do senior executives and board members undergo mandatory security awareness training? 2. Does the board understand their information security roles and responsibilities? This can be part of the contract or part of the onboarding process.	Fail	Board members don't usually have company email accounts and don't get onboarded to the business like normal employees. Cyber security risk is not managed in this organisation and thus the board members don't appear to be aware of their responsibilities when it comes to information security.
		Physical and information security personnel understand roles and responsibilities.	1.Have cyber security roles and responsibilities have been defined and communicated to staff (including physical security staff)? This can be accomplished through accepting policies and/or awareness training	Pass	
Data Security	Information and records (data) are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information.	Data-at-rest is protected.	1. Is data at rest (in hard drives, SharePoint, etc) encrypted by default? 2. Has the organisation undergone a data discovery activity to discover, classify, and label data? 3. Does the organisation have effective DLP capability to prevent loss of data at rest?	Fail	Data is encrypted by default on Microsoft Office 365. However, data hasn't been identified, classified, or labelled. There is no DLP Capability in place.
		Data-in-transit is protected.	1. Is data in transit encrypted by default? 2. Has the organisation undergone a data discovery activity to discover, classify, and label data? 3. Does the organisation have effective DLP capability to prevent loss of data at rest? 4. Can employees copy data on external USB flash drives?	Fail	
		Assets are formally managed throughout removal, transfers and disposition.	1.Do you have a process to offboard assets? 2. Do you follow a process for data disposal?	Fail	
		Adequate capacity to ensure availability is maintained.	1. Are your critical systems 'highly-available' ? 2. Do you have business continuity plans in place? 3. Do you have protection against Denial of Service Attacks?	Pass	

Copyright 2016

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
		Protections against data leaks are implemented.	1. Describe your Data Loss protection program	Fail	
		Integrity checking mechanisms are used to verify software, firmware and information integrity.	1. This is an outdated control. Ignore this. Most firmware's and software's have this control built-in	Pass	
		The development and testing environment(s) are separate from the production environment.	1. Does the organisation conduct any software development activities? If yes, do they have separate development/testing/production environments?	N/A	
Information Protection Processes and Procedures	Security policies (that address purpose, scope, roles, responsibilities, management commitment, and coordination among organizational entities), processes, and procedures are maintained and used to manage protection of information systems and assets.	A baseline configuration of information technology/industrial control systems is created and maintained.	1. Do you use a Secure Operating Environment (SOE) image for your operating system baseline configuration/installation?	Pass	
		A system development life cycle (SDLC) to manage systems is implemented.	1. Does the organisation conduct any software development activities? If yes, do they follow a software development life cycle process?	N/A	
		Configuration change control processes are in place.	1. Does the organisation follow a well documented change management process that includes documented approvals?	Fail	
		Backups of information are conducted, maintained and tested periodically.	1. Do you have take regular backups? 2. Are backups tested on a regular basis?	Pass	
		Policy and regulations regarding the physical operating environment for organizational assets are met.	1.Is Physical security policy (for buildings and secure facilities) implemented and followed ?	Pass	
		Data is destroyed according to policy.	1. Do you a documented procedure for data disposal? Is it followed across the organisation?	Fail	
		Protection processes are continuously improved.	1.Do data protection processes and procedures get reviewed periodically and undergo continuous improvement ?	Fail	
		Effectiveness of protection technologies is shared with appropriate parties.	1. Does the organization participates in information security sharing with other industry partners? (i.e. do they exchange ideas on how to better protect data with other vendors and industry partners?)	Fail	
		Response plans (incident response and business continuity) and recovery plans (incident recovery and disaster recovery) are in place and managed.	1. Do you have cyber security incident response plans? 2. Do you business continuity and disaster recovery plans?	Fail	
		Response and recovery plans are tested.	1. Determine whether business continuity and incident response tests are performed according to policy and any applicable guidance.	Fail	
		Cybersecurity is included in human resources practices. (e.g., deprovisioning, personnel screening)	1. Does hiring procedures include background checks/screenings for all employees and contractors? 2. Are hiring procedures for positions with access to sensitive information commensurate with a higher level of risk? 3. Do termination/off-boarding procedures get accounts/access disabled in a timely manner?	Pass	
		A vulnerability management plan is developed and implemented.	1. Does the organisation have an effective vulnerability management program?	Fail	
Maintenance	Maintenance and repairs of industrial control and information system components is performed consistent with policies and procedures.	Maintenance and repair of organizational assets is performed and logged in a timely manner, with approved and controlled tools.	1. Does the organisation conduct hardware maintenance on their servers (if they have physical servers) ?	N/A	
		Remote maintenance of organizational assets is approved, logged and performed in a manner that prevents unauthorized access.	1. If the organisation use third-party providers to conduct maintenance on their hardware assets, are maintenance activities logged?	N/A	
otective Technology	Technical security solutions are managed to ensure the security and resilience of systems and assets, consistent with related policies, procedures, and agreements.	Audit/log records are determined, documented, implemented and reviewed in accordance with policy.	1. Determine if audit logs (e.g., security, activity) are maintained and reviewed in a timely manner. Verify the adequacy of the logs to monitor and evaluate IT activities and security events. Consider the following: a. Audit records contain appropriate content (e.g., type of event, when the event occurred, where the event occurred, source of the event, outcome of the event, identity of any individuals or subjects associated with the event). b. Log files are sized such that logs are not deleted prior to review and/or being backed up. c. Audit logs and tools are protected from unauthorized access, modification and deletion. 2. Determine if logs for the following parts of the network are monitored and reviewed: a. Network perimeter (e.g., intrusion detection systems [IDS], firewalls) b. Microsoft systems (e.g., Windows event logs) c. Non-Microsoft systems (e.g., syslog files for Unix/Linux servers, routers, switches)	Fail	Logs don't get reviewed (audited)

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
PR		Removable media is protected and its use restricted according to policy.	1. Does the organisation allow using USB flash drives? If yes, are there policies to restrict copying of sensitive data on flash drives?	Fail	
		Access to systems and assets is controlled, incorporating the principle of least functionality.	1. The principle of "least functionality" essentially means having one system for one specific function. For example, have one server for email, and another server for FTP, and another server as a firewall. As opposed to having everything on one machine. Does the organisation follow this principle?	Pass	Assumption: they use different SaaS solutions for different services
		Communications and control networks are protected.	1. is network traffic encrypted by default? What network security measures do you have in place?	Pass	

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Anomalies and Events	Anomalous activity is detected in a timely manner and the potential impact of events is understood.	A baseline of network operations and expected data flows for users and systems is established and managed.	1.Does the organisation have a SIEM? With a SIEM, you can capture what 'normal' (baseline) traffic looks like (so you can detect anomalies when you see something unusual).	Fail	
		Detected events are analysed to understand attack targets and methods.	1. Does the organisation have an effective process of analysing threats and alerts that are detected?	Fail	
		Event data are aggregated and correlated from multiple sources and sensors.	1. Does the organisation have an effective SIEM solutions? If Yes, Have logs been onboarded successfully to the SIEM?	Fail	
		Impact of events is determined.	1. Does the process of analysing detected events include classifying the event based on its impact and criticality? (i.e. low/medium/high for example)	Fail	
		Incident alert thresholds are established.	1. Are escalation points for alerts established based on impact/criticality?	Fail	
Security Continuous Monitoring	The information system and assets are monitored at discrete intervals to identify cybersecurity events and verify the effectiveness of protective measures.	The network is monitored to detect potential cybersecurity events.	1.Is network traffic monitored for malicious activity? (this is accomplished by having an operational SIEM).	Fail	
		The physical environment is monitored to detect potential cybersecurity events.	1. Does Security events monitoring include the physical security environment? Do you get alerts for physical security breaches?	Pass	
		Personnel activity is monitored to detect potential cybersecurity events.	1. Do you detect unusual and/or malicious activities across the organisation (including physical breaches) ?	Fail	
		Malicious code is detected.	1. If you perform software development activities, do you conduct secure coding scanning? 2. Do you have an anti-malware solution (like Microsoft Defender or crowdstrike, for example) ? 3. What's the coverage of your anti-malware solution? Is it deployed on all end-points? what about servers? do you have Mac-OS ? is it deployed on Linux machines?	Pass	
		Unauthorized mobile code is detected.	1. Do you have an anti-malware solution? Does it scan emails as well as static files?	Pass	
		External service provider activity is monitored to detect potential cybersecurity events.	1. Do you have comprehensive TPRM process? If yes, Do third-party service providers provide you with notification in case of any data breaches? (this should be part of the contract)	Fail	
		Monitoring for unauthorized personnel, connections, devices and software is performed.	1. Can any random devices be hooked and connected to the network or do you only allow registered devices that were configured by your IT team to be connected? (best practice is to only allow devices that meet the minimum security requirements of the organisation) 2. Do you allow USB flash drives in the environment?	Fail	

Sub-Category	*Control Objective*	*Control description*	*Questions to ask*	*Pass/ Fail*	*Comments*
		Vulnerability scans are performed.	1. Do you conduct regulate vulnerability scans? If yes, what's the coverage of your vulnerability scanner?	Pass	Further improvements needed
Detection Processes	Detection processes and procedures are maintained and tested to ensure timely and adequate awareness of anomalous events.	Roles and responsibilities for detection are well defined to ensure accountability.	1. have you defined roles and responsibilities for detection and response? Are they assigned to the IT team or cyber security team? Are the roles clear? Do you use MSSP? Is there a clear contract?	Fail	
		Detection activities comply with all applicable requirements.	1. Is your detection capabilities compliant with rules and regulations that are applicable to your organisation?	Fail	
		Detection processes are tested.	1. Do you perform effectiveness testing against your detection use cases? This can be cyber drills and penetration tests 2. Do you improve your detection use cases based on the test outcomes?	Fail	
		Event detection information is communicated to appropriate parties.	1. Do you have clear communication paths and escalation points for when events are detected? Are they documented?	Fail	
		Detection processes are continuously improved.	1. Do you incorporate 'lessons learned' as part of your incident response? Is there a process to continuously improve detection capabilities?	Fail	

Copyright 2016

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Response Planning	Response processes and procedures are executed and maintained, to ensure timely response to detected cybersecurity events.	Response plan is executed during or after an event.	1. Do you cyber security incident response plans? IF yes, are they actively used during an incident?	Fail	
Communications	Response activities are coordinated with internal and external stakeholders, as appropriate, to include external support from law enforcement agencies.	Personnel know their roles and order of operations when a response is needed.	1. Do incident response plans include clear contact details and escalation points? Have they been tested?	Fail	
		Events are reported consistent with established criteria.	1. Do cyber security incidents get reported as per the defined threshold? How mature is the incident response process?	Fail	
		Information is shared consistent with response plans.	1.Do Incident response plans include clear and transparent escalation in points? If yes, do they include involving law enforcement (when necessary) ?	Fail	
		Coordination with stakeholders occurs consistent with response plans.	1. For escalated incidents, do response plans include details on how to coordinate with various teams when necessary?	Fail	
		Voluntary information sharing occurs with external stakeholders to achieve broader cybersecurity situational awareness.	1. Does your organisation share information security intelligence with the wider community or with industry peers?	Fail	
Analysis	Analysis is conducted to ensure adequate response and support recovery activities.	Notifications from detection systems are investigated.	1. Does your team has a clear process to respond to security alerts? 2. Do you have 24/7 coverage?	Fail	
		The impact of the incident is understood.	1. Does your team document the impact/criticality of incidents as part of their analysis?	Fail	
		Forensics are performed.	1. Does your team have the capability (people/skills and technology) to perform digital forensics analysis when needed?	Fail	
		Incidents are categorized consistent with response plans.	1. Are your incident response plans well structure in a such a way that they prioritise incidents based on criticality?	Fail	
tigation	Activities are performed to prevent expansion of an event, mitigate its effects	Incidents are contained.	1. Ensure Incident response plans follow a standard that ensure that incidents are contained. (such as the SANS incident response plans template)	Fail	
		Incidents are mitigated.	1. Ensure Incident response plans follow a standard that ensure that incidents are mitigated as needed. (such as the SANS incident response plans template)	Fail	

Copyright 2016

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Mitigation	and eradicate the incident.	Newly identified vulnerabilities are mitigated or documented as accepted risk.	1. Do you have a comprehensive vulnerability management program that accounts for new vulnerabilities that are newly discovered (including zero days)? Do you have a process to dealing with them?	Fail	
Improvements	Organizational response activities are improved by incorporating lessons learned from current and previous detection/response activities	Response plans incorporate lessons learned.	1. Do your incident response plans include a "lessons learned" step?	Fail	
		Response strategies are updated.	1. Do you periodically test and update your incident response plans?	Fail	

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Recovery Planning	Recovery processes and procedures are executed and maintained to ensure timely restoration of systems or assets affected by cybersecurity events.	Recovery plan is executed during or after an event.	1. Does your organisation have a disaster recovery plan? Has it been tested?	Pass	
Improvements	Recovery planning and processes are improved by incorporating lessons learned into future activities.	Recovery plans incorporate lessons learned.	1. Do your disaster recovery plans include a "lessons learned" step?	Pass	
		Recovery strategies are updated.	1. Do you perform periodic testing for your disaster recovery plans? Do they get regularly updated as a result?	Pass	
Communications	Restoration activities are coordinated with internal and external parties, such as coordinating centres, Internet Service Providers, owners of attacking systems, victims, other CSIRTs and vendors.	Public relations are managed.	1. Do you improve communication as part of your disaster recovery testing?	Pass	
		Reputation after an event is repaired.	1. Do your disaster recovery plans include a mitigating steps in case of a crisis where the reputation of the organisation is impacted?	Pass	
		Recovery activities are communicated to internal stakeholders and executive and management teams.	1. Do your disaster recovery plans include clear communication and escalation points?	Pass	